System Risk Assessment — Data and Analytics Platform

Larkspur Logistics, Inc. · System Risk Assessment · SRA-2026-04 v1.2

Field	Value
Document id	SRA-2026-04
Version	1.2
Classification	INTERNAL — CONFIDENTIAL
System	Data and Analytics Platform
Owner team	Data Engineering
Assessment date	2026-05-29
Next review	2026-11-29
Assessor	Security Operations (SecOps), with Data Engineering
Exposure	internal
Data classification	Restricted

1. Purpose and scope

This assessment documents the platform that ingests operational data from the booking, warehouse and fleet systems, transforms it, and serves dashboards and reports to the business. The platform holds the most complete copy of customer and shipment data in the company, which is why it is rated Restricted although it is reachable only from internal networks.

2. System overview

Apache Airflow orchestrates about 240 daily pipelines that pull data from the operational databases and partner feeds into the analytics warehouse (PostgreSQL) and the search and log cluster (Elasticsearch). Apache Kafka carries the event streams from the warehouse-management and fleet-telemetry systems. Metabase provides dashboards and ad-hoc queries to about 350 business users; Kibana serves the data engineers and the logistics-control room; Grafana shows platform health. Around 180 Data Engineering users and analysts have Airflow or Kibana access.

Data classification is Restricted: the warehouse contains customer personal data (contacts, addresses), shipment contents and values, pricing, and in the HR mart, employee data. Metabase users see only the marts their group is entitled to through its sandboxing feature. Availability tier is Tier 2 (business hours, eight-hour recovery objective); pipelines can be replayed.

Staff authenticate through the Keycloak staff realm with MFA: Metabase and Kibana through OIDC, Airflow through its Flask-AppBuilder (FAB) auth manager configured with Keycloak as the OAuth provider. Analysts with native-query permission in Metabase can write SQL against the warehouse marts.

3. Architecture and hosts

The platform runs on a dedicated Kubernetes cluster (the "data cluster") on the internal segment for Airflow, Metabase, Kibana and Grafana, and on virtual machines for PostgreSQL, Elasticsearch and Kafka. Airflow uses the KubernetesExecutor; pipeline code is deployed from the CI/CD platform by a GitLab pipeline. Metabase connects to the warehouse with read-only accounts per user group; the

Metabase application database is PostgreSQL. The default sample database shipped with Metabase (H2) is still present (finding F-2026-042).

Elasticsearch stores the operational log and the shipment-event index used by the control room; the machine-learning features are licensed and used by two anomaly-detection jobs maintained by Data Engineering, who can upload trained models. Kafka runs as a three-broker cluster with SASL/SCRAM authentication and TLS.

3.1 Host inventory

Hostname	IP address	Zone	Role	Operating system
k8s-data-cp-01..03.corp.example	198.51.100.140-142	Internal (data)	Kubernetes control plane (data cluster)	Ubuntu 24.04 LTS
k8s-data-w-01..08.corp.example	198.51.100.143-150	Internal (data)	Kubernetes workers (Airflow	Ubuntu 24.04 LTS
dwh-db-01.corp.example	198.51.100.160	Internal (data)	PostgreSQL warehouse primary	RHEL 9.5
dwh-db-02.corp.example	198.51.100.161	Internal (data)	PostgreSQL warehouse replica	RHEL 9.5
es-data-01..03.corp.example	198.51.100.165-167	Internal (data)	Elasticsearch nodes	RHEL 9.5
kafka-01..03.corp.example	198.51.100.170-172	Internal (data)	Kafka brokers	RHEL 9.5
bastion-01.mgmt.corp.example	192.0.2.5	Management	SSH bastion (MFA)	Ubuntu 24.04 LTS

4. Software bill of materials

The components below were confirmed from package manifests and running processes during the assessment. Versions are as deployed on the assessment date.

Component	Vendor / project	Version	Role in the system	Deployed on
Metabase	Metabase Inc.	1.58.12	Dashboards and ad-hoc queries for business users	data cluster (namespace metabase)
Apache Airflow	Apache Software Foundation	3.1.2	Pipeline orchestration	data cluster (namespace airflow)
Apache Airflow FAB provider (apache-airflow-providers-fab)	Apache Software Foundation	3.7.5	Authentication and authorisation manager for Airflow	data cluster (namespace airflow)
Apache Airflow Apache Kafka provider (apache-airflow-providers-apache-kafka)	Apache Software Foundation	1.16.0	Kafka operators and hooks used by the ingestion pipelines	data cluster (namespace airflow)
Elasticsearch	Elastic	9.4.2	Operational log and shipment-event index; anomaly-detection models	es-data-01..03
Kibana	Elastic	9.4.2	Dashboards for data engineers and the control room; Fleet management	data cluster (namespace elastic)
Grafana	Grafana Labs	12.1.0	Platform health dashboards	data cluster (namespace monitoring)
PostgreSQL	PostgreSQL Global Development Group	17.4	Analytics warehouse and the Metabase and Airflow application databases	dwh-db-01, dwh-db-02

Component	Vendor / project	Version	Role in the system	Deployed on
Apache Kafka	Apache Software Foundation	3.9.1	Event streams from warehouse management and fleet telemetry	kafka-01..03

4.1 Component notes

Metabase 1.58.12

Metabase 1.58.12 (Pro) with Keycloak OIDC login, sandboxed marts per group, and native-query permission granted to 42 analysts. Database connections are managed by three Data Engineering administrators; the warehouse connection is read-only. The H2 sample database that ships with Metabase has not been removed (F-2026-042). The /reset_password endpoint is exposed to all internal users on the application's virtual host. Upgrades are applied monthly from the vendor's container image.

Apache Airflow 3.1.2

Apache Airflow 3.1.2 with the KubernetesExecutor. Authentication uses the FAB auth manager with Keycloak as the OAuth provider; database-backed sessions are enabled. API clients (the GitLab deployment pipeline and two monitoring scripts) authenticate with bearer tokens. The Kafka event producer (dag_run_events_enabled, task_instance_events_enabled) is disabled, which is the default. Connections may be edited by 11 Data Engineering users with the Op role.

Apache Airflow FAB provider (apache-airflow-providers-fab) 3.7.5

The FAB provider 3.7.5 supplies the auth manager. It is configured with Keycloak as the OAuth provider, not Azure AD, and with session_backend set to database. Password resets are rare because Keycloak is the identity source, but local FAB accounts exist for the two break-glass administrators.

Apache Airflow Apache Kafka provider (apache-airflow-providers-apache-kafka) 1.16.0

The Kafka provider 1.16.0 is used by the ingestion DAGs through Kafka connections whose extra field holds the SASL settings. The scheduler-side event producer is not enabled (see Airflow notes), so provider code runs in task pods rather than in the scheduler.

Elasticsearch 9.4.2

Elasticsearch 9.4.2 (Platinum licence) as a three-node cluster with TLS and role-based access. The machine-learning node role is enabled on all three nodes; the manage_ml privilege, which allows uploading and deploying trained models, is held by the six members of the Data Engineering anomaly-detection group.

Kibana 9.4.2

Kibana 9.4.2 with Keycloak OIDC and Spaces per team. Fleet is used to manage the log-shipping agents on the platform hosts; delegated Fleet package-management privileges are held by the platform SRE group in addition to the Elastic administrators.

Grafana 12.1.0

Grafana OSS 12.1.0 with Keycloak OIDC. Plugins are installed by the two Grafana administrators from the public catalogue through the administration UI; eleven plugins are installed, all signed. Dashboards read from Prometheus and from the warehouse replica.

PostgreSQL 17.4

PostgreSQL 17.4 primary and streaming replica; the replica serves Metabase and Grafana reads. Row-level security backs the Metabase sandboxing for the HR mart.

Apache Kafka 3.9.1

Three brokers in KRaft mode with SASL/SCRAM and TLS; ACLs per producing and consuming service account.

5. Network exposure

The platform is internal: nothing is reachable from the internet. Metabase is reachable from the office networks and the VPN by all staff with an account; Airflow, Kibana and Grafana from the Data Engineering and SRE groups' networks; the databases, Elasticsearch and Kafka only from the data cluster and the bastion.

The main exposure is the number of authenticated users with query or model privileges: 42 analysts can run native SQL in Metabase, 11 engineers can edit Airflow connections, and 6 can deploy machine-learning models in Elasticsearch. Those privileges are the preconditions of several of the vulnerabilities this platform's components have had.

5.1 Exposed endpoints

Port / protocol	Service	Reachable from	Authentication
443/tcp	Metabase	Office networks and VPN (all staff)	Keycloak OIDC (MFA); password reset endpoint exposed
443/tcp	Airflow web UI and REST API	Data Engineering and SRE networks; CI/CD pipeline	FAB auth manager with Keycloak OAuth; bearer tokens for API clients
443/tcp	Kibana	Data Engineering	Keycloak OIDC (MFA)
443/tcp	Grafana	Data Engineering and SRE networks	Keycloak OIDC (MFA)
9200/tcp	Elasticsearch REST	Data cluster and bastion	TLS + role-based API keys
9093/tcp	Kafka (SASL_SSL)	Data cluster	SASL/SCRAM + ACLs
5432/tcp	PostgreSQL warehouse	Data cluster and bastion	SCRAM + TLS

6. Security controls

Control	Status	Last verified	Notes
Not reachable from the internet	In place	2026-05-20	No ingress; egress through the proxy for partner feeds.
SSO with MFA for staff on all web applications	In place	2026-05-20	Two local FAB break-glass accounts in Airflow.
Read-only warehouse connections for Metabase; sandboxing per group	In place	2026-05-20	Row-level security on the HR mart.
Least privilege for model deployment and connection editing	Partial	2026-05-20	Privileges reviewed quarterly; counts in section 5.

Control	Status	Last verified	Notes
Weekly authenticated vulnerability scan; container images scanned in Harbor	In place	2026-05-25	All hosts and images.
Centralised logging to the SIEM	In place	2026-05-20	Audit logs of Airflow
Backups and replay of pipelines	In place	2026-05-02	See Appendix B.

7. Open findings

Id	Severity	Finding	Owner	Due
F-2026-041	Medium	Two local break-glass accounts in Airflow use FAB passwords without MFA.	Data Engineering	2026-09-30
F-2026-042	Low	The Metabase H2 sample database is still present on the production instance.	Data Engineering	2026-08-31
F-2026-043	Medium	Grafana plugins are installed from the public catalogue without an allowlist.	Data Engineering	2026-10-31

8. Ownership and contacts

Role	Name	Contact
Owner Team lead	Yuki Tanaka	yuki.tanaka@larkspur-logistics.example
Technical lead (Airflow and warehouse)	Mateusz Nowak	mateusz.nowak@larkspur-logistics.example
Technical lead (Elastic stack and Kafka)	Chloé Dubois	chloe.dubois@larkspur-logistics.example
Metabase administrator	Samuel Adeyemi	samuel.adeyemi@larkspur-logistics.example
SecOps liaison	Priya Nandakumar	secops@larkspur-logistics.example

Data Engineering owns the platform. The data cluster's Kubernetes infrastructure is operated by Platform Engineering under the CI/CD platform's processes; application upgrades are Data Engineering's responsibility.

9. Assessment history

Date	Version	Summary
2025-03-07	1.0	Initial assessment after the move to the data cluster.
2025-11-21	1.1	Airflow 3 migration and Kafka event streams added.
2026-05-29	1.2	Annual review; three findings open; privilege counts recorded.

Appendix A. Service and port matrix

Host	Port	Service	Listens on	Purpose
data cluster ingress	443	NGINX ingress controller	198.51.100.139	Metabase
dwh-db-01/02	5432	PostgreSQL	198.51.100.160-161	Warehouse and application databases
es-data-01..03	9200	Elasticsearch	198.51.100.165-167	Search and ML
es-data-01..03	9300	Elasticsearch transport	198.51.100.165-167	Cluster traffic
kafka-01..03	9093	Kafka SASL_SSL	198.51.100.170-172	Event streams

Appendix B. Backup, recovery and change management

Backups: the warehouse uses streaming replication and nightly base backups with WAL archiving to the object store (recovery point 15 minutes); Elasticsearch takes nightly snapshots to the object store; Kafka topics are retained for seven days and all pipelines are replayable from the source systems. The Metabase and Airflow application databases are included in the nightly warehouse backup. A restore was exercised on 2026-05-02.

Change management: component upgrades are scheduled through the weekly CAB; Metabase and the Airflow providers are upgraded monthly, Elasticsearch and Kibana quarterly, Kafka twice a year. Pipeline code changes go through merge requests and the GitLab deployment pipeline.

Appendix C. Change log

Date	Change	Approved by
2026-03-06	Elasticsearch and Kibana upgraded to 9.4.2.	CAB
2026-04-10	Airflow upgraded to 3.1.2; FAB provider 3.7.5 and Kafka provider 1.16.0.	CAB
2026-05-08	Metabase upgraded to 1.58.12.	CAB
2026-05-15	Grafana upgraded to 12.1.0.	CAB